

PYTHON O CÓDIGO DA
RESISTÊNCIA CONTRA O IMPÉRIO

AVALIAÇÃO DE VULNERABILIDADES



11

LISTA DE FIGURAS

Figura 1 – Configurações de rede da máquina virtual Kali Linux	8
Figura 2 – Acesso à aplicação OpenVAS no Kali Linux	9
Figura 3 – Instalação do OpenVAS no Kali Linux.....	10
Figura 4 – Configuração do OpenVAS no Kali Linux.....	11
Figura 5 – Processo final de configuração do OpenVAS. Serviços, usuário e senha	12
Figura 6 – Tela de <i>login</i> do OpenVAS.....	13
Figura 7 – Configurações de rede da máquina virtual Windows Server	14
Figura 8 – Configurações TPC/IP do Windows Server.....	15
Figura 9 – Configurações do sistema de destino	16
Figura 10 – Definição de um novo sistema de destino.....	16
Figura 11 – Definição das informações do sistema de destino	17
Figura 12 – Sistema de destino cadastrado	18
Figura 13 – Definição de uma nova tarefa para verificação do sistema de destino...19	
Figura 14 – Iniciar uma nova tarefa para verificação do sistema de destino	19
Figura 15 – Relatório de tarefa de verificação do sistema de destino	20
Figura 16 – Relatório de vulnerabilidades do sistema alvo	21
Figura 17 – Relatório da vulnerabilidade em detalhes	22
Figura 18 – Página de registro para uso do Nessus Essentials	23
Figura 19 – Instalação do <i>Nessus Essentials</i>	24
Figura 20 – Instalação do <i>plug-ins</i> do <i>Nessus Essentials</i>	25
Figura 21 – Painel <i>My Scans</i> do <i>Nessus Essentials</i>	26
Figura 22 – <i>Painel Scan Template</i> do <i>Nessus Essentials</i>	27
Figura 23 – <i>Painel Basic Network Scan</i> do <i>Nessus Essentials</i>	27
Figura 24 – Resultado da verificação de vulnerabilidades no sistema Windows Server 2008.....	28
Figura 25 – Resultados priorizados de verificações de vulnerabilidades	30

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Instalação do OpenVAS.....	10
Comando de prompt 2 – Configuração do OpenVAS.....	10
Comando de prompt 3 – Instalação do Nessus Essentials utilizando dpkg	24
Comando de prompt 4 – Subindo o daemon do Nessus Essentials.....	24
Comando de prompt 5 – Endereço de navegador para acesso do painel do Nessus Essentials	24

EMANIP

SUMÁRIO

1 GESTÃO DE VULNERABILIDADE	5
2 ETAPA 1: ESCOPO DOS SISTEMAS	5
3 ETAPA 2: AVALIANDO O STATUS DA SEGURANÇA.....	6
4 COM QUE FREQUÊNCIA VOCÊ DEVE VERIFICAR SEU AMBIENTE COMPUTACIONAL?	6
5 OPÇÕES DE FERRAMENTAS PARA VERIFICAÇÃO	7
5.1 Um elemento importante na gestão de vulnerabilidades.....	7
6 CENÁRIO	7
7 INSTALANDO E CONFIGURANDO O OPENVAS NO KALI LINUX	9
7.1 Iniciando o OpenVAS	12
7.2 Acessando o OpenVAS.....	12
7.3 Em qual sistema serão verificadas as vulnerabilidades?	13
7.4 Definindo o sistema-alvo	15
8 INSTALANDO E CONFIGURANDO O NESSUS ESSENTIALS NO KALI LINUX..	22
9 ETAPA 3: PRIORIZANDO OS RESULTADOS DA VERIFICAÇÃO	29
10 ETAPA 4: CORRIGINDO VULNERABILIDADES	30
11 INFORMES DE VULNERABILIDADE PRECISOS	32
11.1 Etapa 5: Mantendo-se informado	32
12 UMA SOLUÇÃO PARA VERIFICAÇÃO DE VULNERABILIDADES	32
13 ETAPA 6: REPETIR CONTINUAMENTE	33
REFERÊNCIAS.....	35

1 GESTÃO DE VULNERABILIDADE

Na prática, gestão de vulnerabilidades significa encontrar e eliminar de forma sistemática e contínua as vulnerabilidades nos sistemas de seu computador. Muitas etapas ou processos envolvidos na gestão de vulnerabilidades usam a tecnologia a seu favor, ou seja, usam ferramentas de teste automatizadas, como scanners de segurança, porém, em outras etapas, precisam da equipe de TI para implementar patches, atualizações de software e acompanhamentos. A integração desses processos produz maior segurança e proteção do sistema computacional e da rede de sua organização.

Vamos começar mostrando seis etapas para estabelecer as bases de um programa bem-sucedido para gestão de vulnerabilidades e com mais detalhes, como podem ser aplicadas na prática em um procedimento de avaliação de vulnerabilidades.

2 ETAPA 1: ESCOPO DOS SISTEMAS

Para encontrar vulnerabilidades, você deve primeiro descobrir quais ativos (como servidores, *desktops*, dispositivos móveis) estão disponíveis em sua rede, ou seja, criar um inventário. Esse processo também envolve descobrir se existem dispositivos “esquecidos” no seu ambiente. Você também precisa identificar as pessoas responsáveis por manter esses ativos, ou seja, seus proprietários.

O principal objetivo do escopo, também chamado de descoberta de ativos, é organizar seus sistemas de computadores de acordo com o papel que eles desempenham nos seus negócios, para estabelecer uma linha de base de avaliação.

Geralmente, o processo do escopo começa no início de uma verificação de gestão de vulnerabilidades e a solução de tecnologia escolhida, gera um banco de dados com todos os sistemas de computador e dispositivos de rede com um endereço IP (*Internet Protocol*) conectado à sua rede.

Aplicações como *Total Network Inventory*, *Network Inventory Advisor* e *Spiceworks* são utilizadas, porém versões mais completas são pagas.

3 ETAPA 2: AVALIANDO O STATUS DA SEGURANÇA

A avaliação de vulnerabilidades é o processo fundamental para encontrar e posteriormente propor correções para as fragilidades existentes nos sistemas. Você pode executar uma avaliação por meio do processo de verificação de vulnerabilidades de duas maneiras:

- Uma verificação única que fornece uma ideia do status de segurança dos sistemas em seu computador;
- Uma varredura que é executada repetidamente e periodicamente, por exemplo, diariamente ou semanalmente. Mais do que isso, muitos especialistas julgam que é tempo demais. Ainda nesse caso, você deve acompanhar a velocidade da aplicação de patches e atualizações de software e avaliar como o status de segurança está melhorando. Esse nível de avaliação fornece mais informações úteis para uma gestão de vulnerabilidades eficaz.

Nos dois casos, fazer uma verificação envolve duas etapas

1. O scanner usa sua biblioteca, contendo dados sobre as vulnerabilidades, para testar e analisar sistemas, serviços e aplicativos quanto a falhas de segurança conhecidas.
2. Um relatório pós-verificação organiza e prioriza as vulnerabilidades reais e fornece informações para a aplicação de patches e atualizações.

4 COM QUE FREQUÊNCIA VOCÊ DEVE VERIFICAR SEU AMBIENTE COMPUTACIONAL?

Os dados de inventário dos ativos, configuração e vulnerabilidade coletados pelo seu *scanner* são essenciais para manter de forma contínua o monitoramento da segurança da informação.

Sem novos dados, o monitoramento não é contínuo e os sistemas estarão em risco. Portanto, para obter melhores resultados, sugerimos que você verifique seus sistemas mais importantes junto com seus ativos estratégicos e de alto valor diariamente e de forma contínua.

Você pode se perguntar: mas o que deve ser escaneado? E a resposta é simples: praticamente qualquer dispositivo que esteja conectado à rede da sua organização. Por exemplo, você pode escanear servidores, estações de trabalho, dispositivos de rede em qualquer um dos departamentos da organização.

5 OPÇÕES DE FERRAMENTAS PARA VERIFICAÇÃO

5.1 Um elemento importante na gestão de vulnerabilidades

A escolha que você faz em relação à tecnologia (aplicação) para escanear os sistemas é um elemento importante de uma implementação para uma gestão de vulnerabilidades eficaz. Existem várias opções disponíveis, algumas você pode obter de forma gratuita e outras não, isto é, são pagas.

Algo em comum, na maioria dessas aplicações, é que todas usam um banco de dados com informações sobre vulnerabilidades, inclusive devem estar atualizadas com as mais recentes. Mas esses bancos de dados variam em cobertura, qualidade e frequência efetivas de recebimento de atualizações de vulnerabilidades. Tradicionalmente, os scanners instalados localmente exigem que você realize o gerenciamento e os mantenha atualizados.

A partir de agora, serão apresentadas duas aplicações que podem ajudar você a realizar scanner e descobrir as vulnerabilidades existentes em um ambiente.

1. A primeira é o **Open Vulnerability Assessment System (OpenVAS)**, que é um *framework* contendo vários serviços e ferramentas que oferecem uma abrangente e poderosa solução para scanner e gerenciamento de vulnerabilidade.
2. A segunda é o **Nessus Essentials**, que apresenta uma solução de avaliação de vulnerabilidades mais amplamente implantada no setor e ajuda a reduzir a superfície de ataque da sua organização e garantir a conformidade (TENABLE, s.d). Observe que essa versão gratuita do Nessus é dedicada para educadores e estudantes.

6 CENÁRIO

A verificação de vulnerabilidades é o primeiro passo para quem deseja descobrir as fraquezas do ambiente e propor soluções para mitigá-las. Primeiro você

entenderá como o OpenVAS pode ser usado para escanear computadores em rede e descobrir quais são as vulnerabilidades existentes.

Posteriormente, as informações descobertas podem ser utilizadas para corrigir e proteger os sistemas de possíveis invasores, ou seja, de pessoas não autorizadas que podem utilizar essas fraquezas para explorarem as vulnerabilidades existentes.

Para que você possa desenvolver a parte prática, a partir desse momento, utilize uma aplicação para gerar máquinas virtuais de sua preferência. Optamos por usar um sistema operacional com a distribuição Kali Linux e uma versão do sistema operacional Microsoft Windows Server 2008, ambos disponíveis em máquinas virtuais.

Vale lembrar que você deve certificar-se de que a máquina virtual se encontra configurada para que o sistema operacional tenha acesso à Internet. A Figura 1 apresenta as configurações de rede da aplicação VirtualBox, o modo como foi configurada permite que o sistema operacional consiga acesso à rede e, por conseguinte, obtenha configurações TCP/IP de forma automática de um servidor **DHCP** (*Dinamic Host Configuration Protocol*) existente.

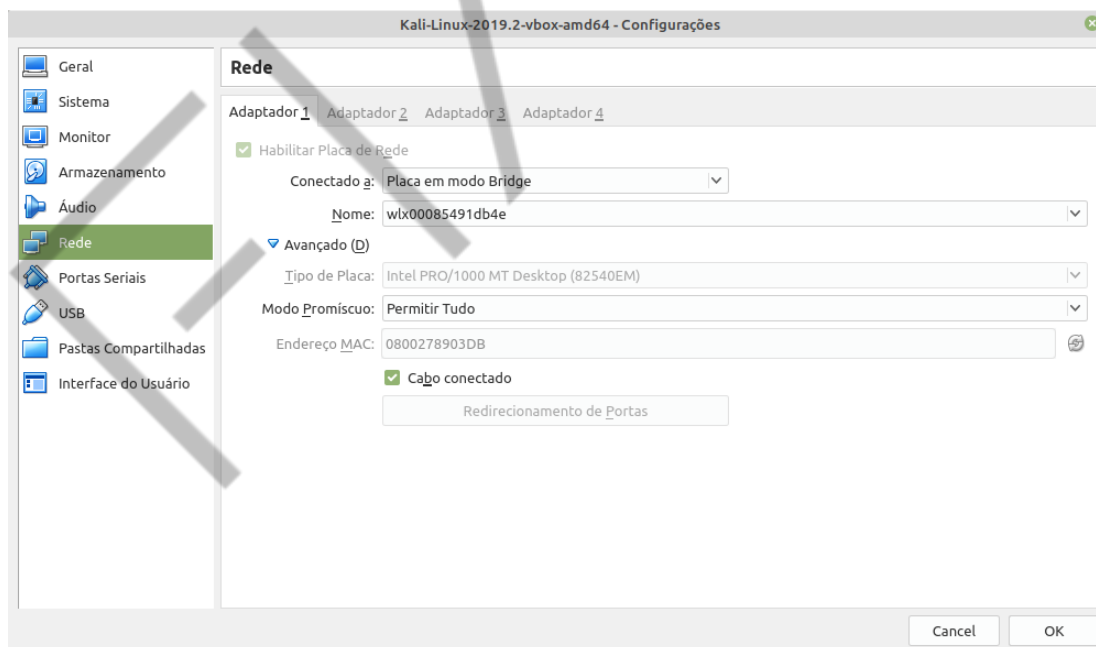


Figura 1 – Configurações de rede da máquina virtual Kali Linux
Fonte: Elaborado pelo autor (2020)

A máquina virtual com o Kali Linux conterá as duas aplicações para escanear: o OpenVAS e o Nessus Essentials. A máquina virtual com Microsoft Windows Server 2008 será considerada como um sistema alvo, ou seja, aquela que contém as

possíveis vulnerabilidades. Vale registrar que para efeito de experimentos, o sistema operacional Windows foi somente instalado e não optamos por fazer qualquer tipo de atualização propositadamente, aumentando, assim, as chances de encontrar o maior número de vulnerabilidades.

Importante: Se você gosta ou tem familiaridade com outra distribuição Linux, fique à vontade para utilizá-la. Além disso, o sistema alvo também pode ser qualquer outro sistema operacional que você tenha disponível.

Para que você possa continuar, é importante disponibilizar o acesso aos sistemas operacionais (Kali Linux e Microsoft Windows) a partir das máquinas virtuais. Se você tem algo pronto, ótimo. Caso contrário, deverá instalá-los para prosseguir.

7 INSTALANDO E CONFIGURANDO O OPENVAS NO KALI LINUX

Se suas máquinas virtuais estão prontas, você pode começar verificando se a versão do Kali Linux disponibiliza o OpenVAS. Observe que a Figura 2 apresenta os menus para que você possa descobrir se a aplicação está instalada e posteriormente também possa iniciá-la.

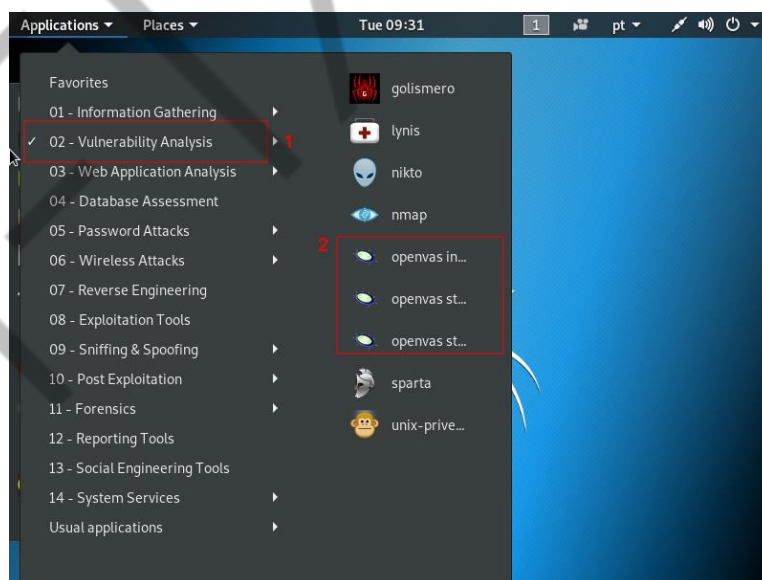


Figura 2 – Acesso à aplicação OpenVAS no Kali Linux
Fonte: Elaborado pelo autor (2020)

Se o seu sistema operacional Linux não conta com o OpenVAs, então você deve aproveitar os seguintes passos para instalá-lo, caso contrário, você pode ir direto para a parte de inicialização, mais adiante neste material.

Contudo, antes de iniciar a instalação do OpenVAS, vamos verificar se o sistema operacional Kali está atualizado.

1. Abra o emulador de terminal e por meio do comando `apt update`, realize o procedimento de atualização da lista de repositórios. Lembre-se de estar logado como usuário root.

2. Em seguida, para instalar o OpenVAS, execute a seguinte linha de comando:

```
apt install openvas
```

Comando de prompt 1 – Instalação do OpenVAS

Fonte: Elaborado pelo autor (2020)

A Figura “Instalação do OpenVAS no Kali Linux” mostra a linha de comando sendo executada a partir do terminal.

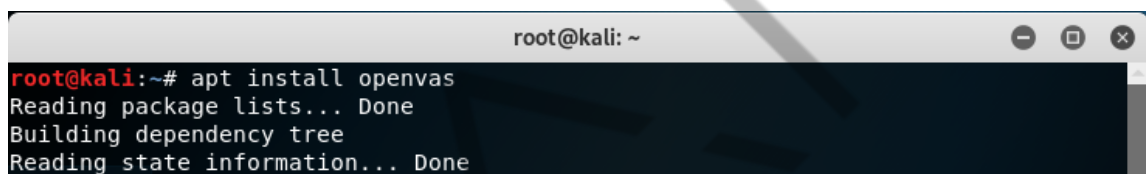


Figura 3 – Instalação do OpenVAS no Kali Linux

Fonte: Elaborado pelo autor (2020)

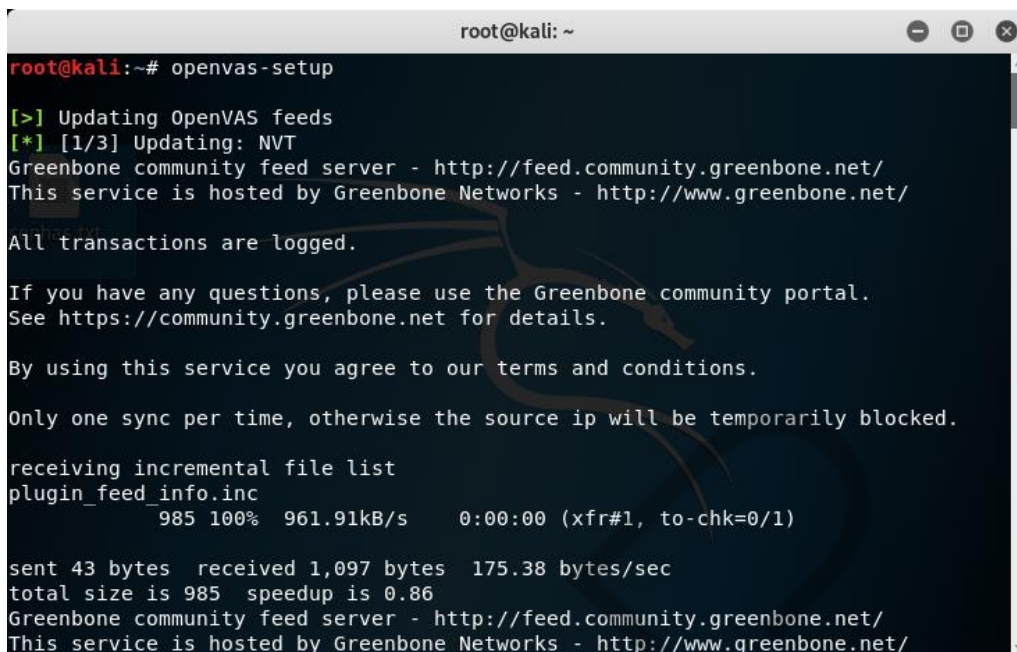
3. Agora você deve iniciar o processo de configuração com linha de comando:

```
openvas-setup
```

Comando de prompt 2 – Configuração do OpenVAS

Fonte: Elaborado pelo autor (2020)

A Figura “Configuração do OpenVAS no Kali Linux” mostra a linha de comando sendo executada a partir do terminal.



```
root@kali:~# openvas-setup

[>] Updating OpenVAS feeds
[*] [1/3] Updating: NVT
Greenbone community feed server - http://feed.community.greenbone.net/
This service is hosted by Greenbone Networks - http://www.greenbone.net/

All transactions are logged.

If you have any questions, please use the Greenbone community portal.
See https://community.greenbone.net for details.

By using this service you agree to our terms and conditions.

Only one sync per time, otherwise the source ip will be temporarily blocked.

receiving incremental file list
plugin_feed_info.inc
      985 100% 961.91kB/s   0:00:00 (xfr#1, to-chk=0/1)

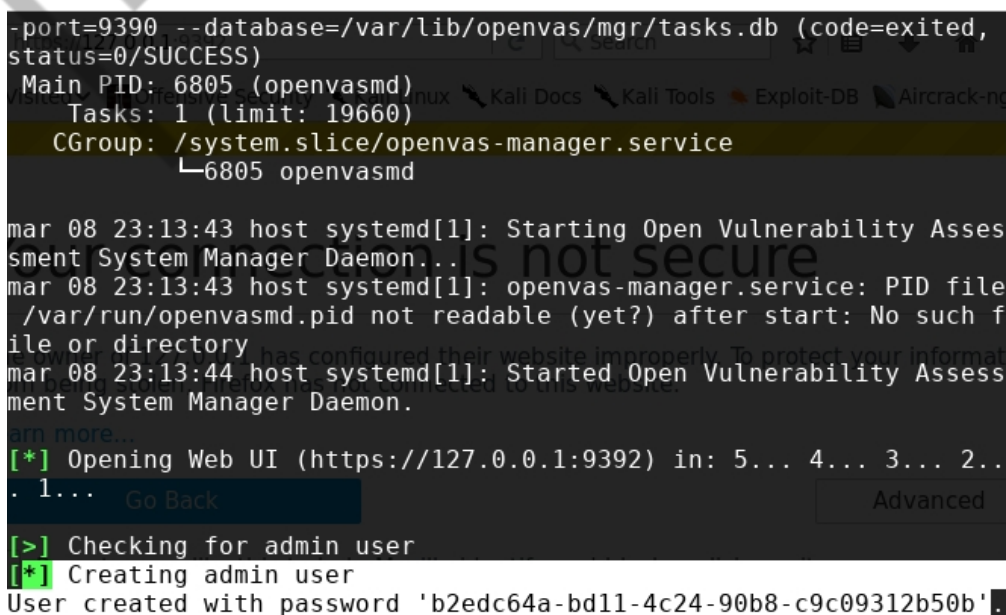
sent 43 bytes  received 1,097 bytes  175.38 bytes/sec
total size is 985  speedup is 0.86
Greenbone community feed server - http://feed.community.greenbone.net/
This service is hosted by Greenbone Networks - http://www.greenbone.net/
```

Figura 4 – Configuração do OpenVAS no Kali Linux

Fonte: Elaborado pelo autor (2020)

Quando o processo de configuração do OpenVAS estiver concluído, não fique ansioso, muitas vezes, esse processo é um tanto quanto demorado, o scanner e os serviços relacionados estão prontos para uso.

Fique atento, já que, ao final da configuração, será criado um usuário administrativo, chamado admin, e os serviços relacionados serão iniciados, como mostrado na Figura “Processo final de configuração do OpenVAS. Serviços, usuário e senha”. Anote ou copie a senha apresentada no final da instalação para uso posterior.



```
-port=9390 --database=/var/lib/openvas/mgr/tasks.db (code=exited,
status=0/SUCCESS)
Main PID: 6805 (openvasmd)
Tasks: 1 (limit: 19660)
CGroup: /system.slice/openvas-manager.service
└─6805 openvasmd

mar 08 23:13:43 host systemd[1]: Starting Open Vulnerability Asses
sment System Manager Daemon...
mar 08 23:13:43 host systemd[1]: openvas-manager.service: PID file
/var/run/openvasmd.pid not readable (yet?) after start: No such f
ile or directory
mar 08 23:13:44 host systemd[1]: Started Open Vulnerability Asses
sment System Manager Daemon.
arn more...
[*] Opening Web UI (https://127.0.0.1:9392) in: 5... 4... 3... 2..
. 1... Go Back Advanced

[>] Checking for admin user
[*] Creating admin user
User created with password 'b2edc64a-bd11-4c24-90b8-c9c09312b50b'.
```

Figura 5 – Processo final de configuração do OpenVAS. Serviços, usuário e senha
Fonte: Elaborado pelo autor (2020)

7.1 Iniciando o OpenVAS

Você pode optar por iniciar o serviço do OpenVAS de duas maneiras:

1. A partir da interface gráfica, como mostrado na Figura “Acesso a aplicação OpenVAS no Kali Linux”, você pode selecionar o menu *Vulnerability Analysis* e a opção **openvas start**;

2. A partir do terminal, digitar o comando: **openvas-start**;

Se acontecer algum problema relacionado ao serviço e o OpenVAS não for inicializado, você pode utilizar a partir do terminal o comando **openvas-check-setup** e tentar identificar o que está acontecendo de errado.

7.2 Acessando o OpenVAS

Muitas vezes, o procedimento realizado anteriormente é suficiente para que o OpenVAS seja apresentado a partir de uma interface web (navegador padrão). No entanto, se não for suficiente, você deve abrir um navegador de sua preferência e utilizar o endereço local e identificação de porta `http://172.0.0.1:9392` para obter acesso à interface. Se solicitado, adicione no navegador uma exceção para essa conexão.

A **Greenbone Networks GmbH** desenvolveu a interface gráfica para escanear o OpenVAS e, assim que o procedimento for iniciado, o navegador apresenta o "Greenbone Security Assistant" com um *prompt de login*, como mostrado na Figura “Tela de login do OpenVAS”. Digite as credenciais para o usuário e senha, criados ao final da instalação. Se preferir, após digitar o usuário admin, você pode colar a senha copiada anteriormente no campo **Password**.

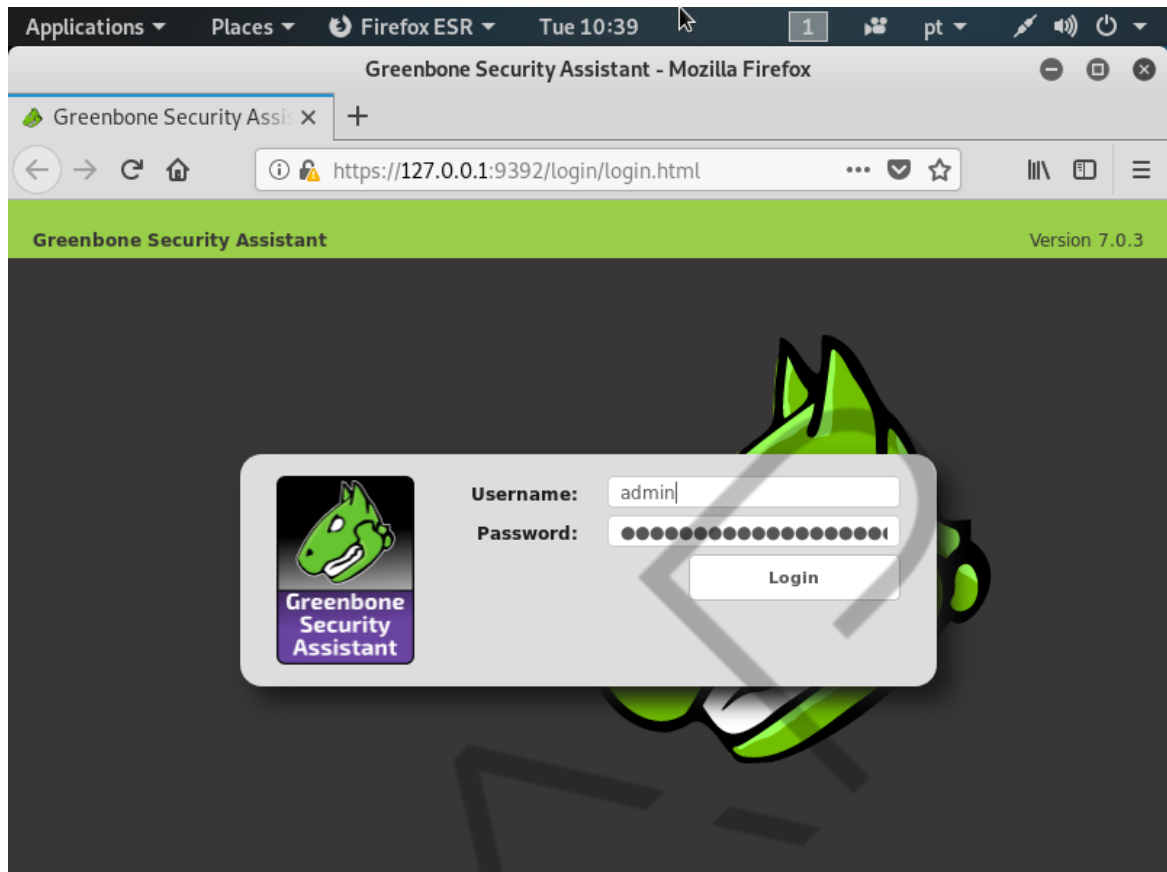


Figura 6 – Tela de *login* do OpenVAS
Fonte: Elaborado pelo autor (2020)

A partir do painel de controle (*Dashboard*) do OpenVAS, você consegue visualizar algumas informações importantes, tais como: os níveis de severidade associados a cada tarefa de escanear realizada, a quantidade de tarefas já realizadas, o total de **CVEs** (**Common Vulnerabilities and Exposures**) identificadas, entre outras.

Dica: você pode personalizar essa área de acordo com suas necessidades.

7.3 Em qual sistema serão verificadas as vulnerabilidades?

Como apresentado anteriormente, os sistemas operacionais utilizados serão o Kali Linux e o Windows Server 2008. Dessa forma, você deve considerar como sistema alvo o Windows Server 2008.

Mas antes de continuar e iniciar o sistema operacional, você deve confirmar as configurações de rede da máquina virtual e verificar se a opção “Conectado a:” Placa em modo Bridge está definida. A Figura “Configurações de rede da máquina virtual

Windows Server” exibe mais detalhes da configuração de rede e da mesma forma que aconteceu com o Kali Linux, o Windows deverá obter configurações TCP/IP de forma automática de um servidor DHCP existente.

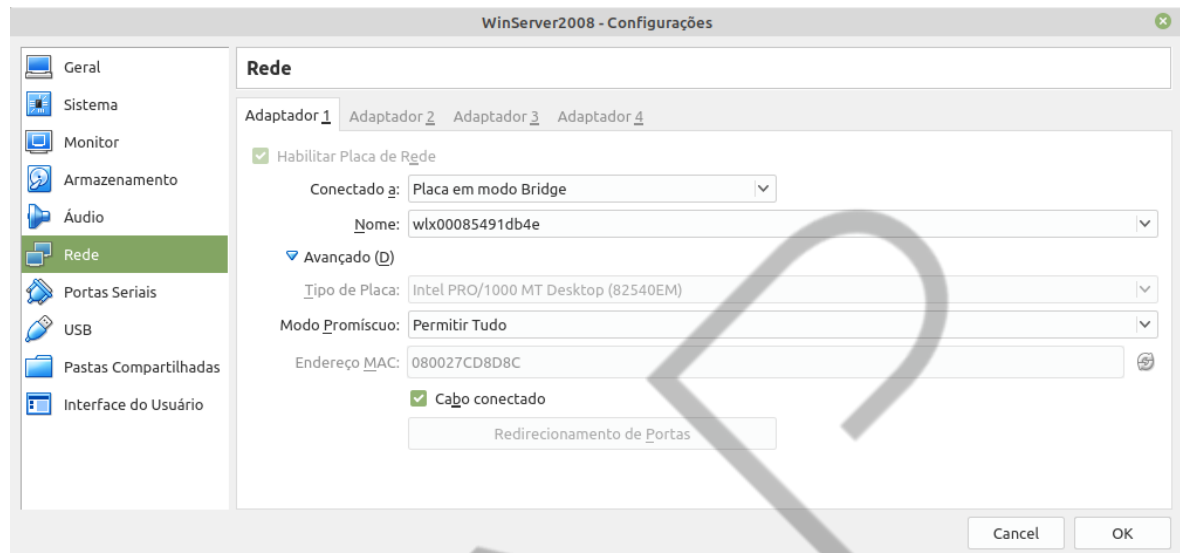


Figura 7 – Configurações de rede da máquina virtual Windows Server
Fonte: Elaborado pelo autor (2020)

Agora sim, você pode iniciar seu sistema operacional Windows e descobrir qual endereço IP foi atribuído a ele. A Figura “Configurações TPC/IP do Windows Server”, mostra o *prompt* de comando com o resultado do comando `ipconfig`, note que o endereço IP atribuído foi o 192.168.1.35. No entanto, em seu computador o endereço IP será outro.

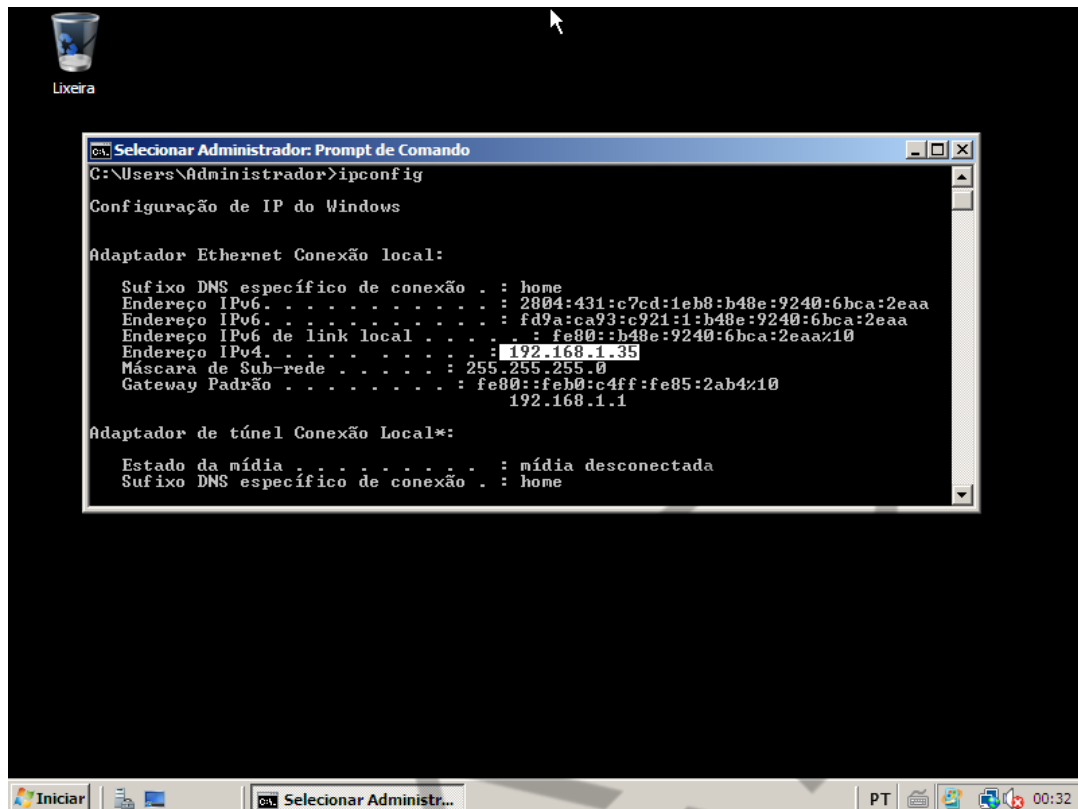


Figura 8 – Configurações TPC/IP do Windows Server

Fonte: Elaborado pelo autor (2020)

A partir de agora, você sabe qual é a identificação do sistema alvo, ou seja, o endereço IP do *host* de destino.

7.4 Definindo o sistema-alvo

1) A partir da máquina virtual com o Kali Linux, utilize o OpenVAS para definir quem será analisado, isto é, o host alvo no qual o processo de verificação de vulnerabilidades será executado. Na barra de navegação, selecione no menu *Configuration* a opção *Target*, como mostrado na Figura “Configurações do sistema de destino”.



Figura 9 – Configurações do sistema de destino
 Fonte: Elaborado pelo autor (2020)

2) Em seguida, selecione o botão New Target (Novo Destino), como mostrado na Figura “Definição de um novo sistema de destino”.

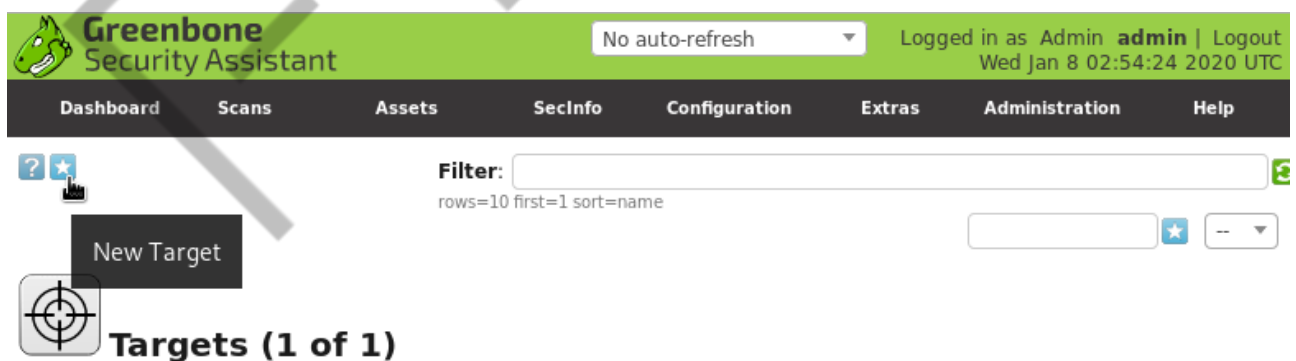


Figura 10 – Definição de um novo sistema de destino
 Fonte: Elaborado pelo autor (2020)

3) Após clicar no botão *New Target* (Novo Destino), uma nova janela é exibida, como mostrado na Figura “Definição das informações do sistema de destino”. Observe que o campo *Name*, foi preenchido com um texto que associa e identifica o sistema destino, já o campo *Hosts* foi preenchido manualmente, visto que se trata de apenas um host, entretanto, você poderia utilizar um arquivo contendo uma lista com vários endereços Ips, cada um representando um host na rede. Note, ainda, que os demais campos não foram alterados, como *Post List* que contém informações relacionadas às identificações das portas associadas aos serviços, como também o tipo de teste realizado, campo *Alive Test*, que utilizará as configurações padrão do OpenVAS. É claro que com o passar do tempo ou em até outros experimentos, você pode alterar as configurações dos campos.

The screenshot shows the 'New Target' form in OpenVAS. The form is titled 'New Target' in a green header bar. It contains several fields for defining a target system. The 'Name' field is filled with 'Windows Server 2008'. The 'Comment' field is filled with 'Servidor com algumas funções'. The 'Hosts' field is filled with '192.168.1.35'. The 'Exclude Hosts' field is empty. The 'Reverse Lookup Only' and 'Reverse Lookup Unify' fields are both set to 'No'. The 'Port List' field is set to 'All IANA assigned TCP 20...'. The 'Alive Test' field is set to 'Scan Config Default'. The 'Credentials for authenticated checks' field is empty. The 'SSH' field is empty. The 'SMB' field is empty. The 'ESXI' field is empty. The 'SNMP' field is empty. There are also radio buttons for 'Manual', 'From file', and 'From host assets (0 hosts)'. A 'Browse...' button is next to the 'Hosts' field. A 'Create' button is at the bottom right.

Figura 11 – Definição das informações do sistema de destino

Fonte: Elaborado pelo autor (2020)

4) Após preencher essas informações, finalize o procedimento clicando no botão *Create*. Em seguida, será mostrada uma tela semelhante à apresentada na Figura “Sistema de destino cadastrado”, que apresenta informações como nome do sistema destino e hosts com os endereços IPs associados aos sistemas de destino cadastrados. Ao final dessa linha, você pode selecionar ações para excluir, editar, clonar e exportar informações sobre o sistema de destino.

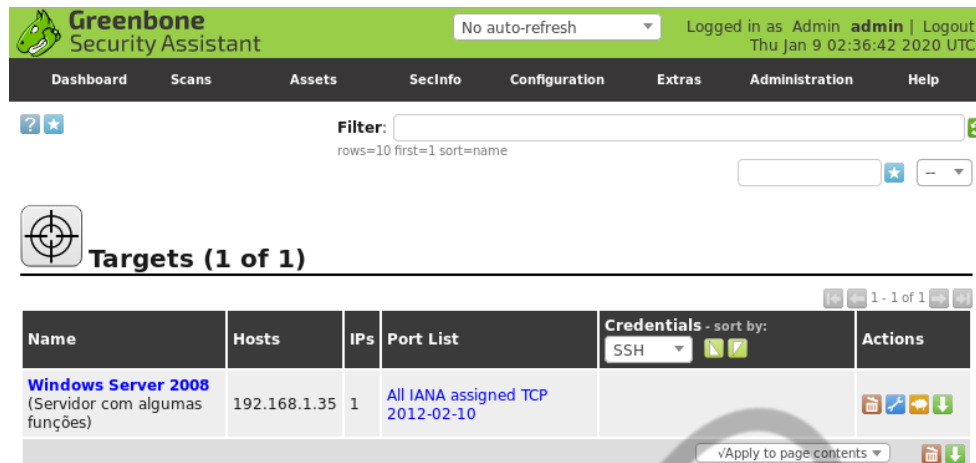


Figura 12 – Sistema de destino cadastrado
Fonte: Elaborado pelo autor (2020)

5) Após definir o sistema que será analisado, você precisa criar uma nova tarefa, para que posteriormente possa realizar a verificação de vulnerabilidades. A sequência é mostrada na Figura “Definição de uma nova tarefa para verificação do sistema de destino”, sendo assim, na barra de navegação selecione no menu *Scans* a opção *Task* e em seguida, selecione o botão *New Task* (Nova Tarefa).

Na Figura “Definição de uma nova tarefa para verificação do sistema de destino”, você ainda pode observar que a janela *New Task* deve ser preenchida. As informações minimamente necessárias são o campo *Name*, para nomear a tarefa e *Scan Targets*, que define qual é o sistema de destino a ser verificado. Após preencher os campos necessários, defina a nova tarefa ao clicar no botão *Create*.

Figura 13 – Definição de uma nova tarefa para verificação do sistema de destino
 Fonte: Elaborado pelo autor (2020)

As informações apresentadas, nos campos da tela *Task*, são: o nome da tarefa que é listado na coluna *Name*, o status da verificação, que mostra a porcentagem de execução da tarefa, a quantidade de relatórios executados para esse sistema, o nível de severidade associado e as ações que podem ser realizadas.

6) Para executar a verificação de vulnerabilidade no sistema de destino, selecione o botão *Start* de cor verde, como destacado na Figura “Iniciar uma nova tarefa para verificação do sistema de destino”.

Dica: você pode atualizar a tela do OpenVAS para que o campo Status possa ser atualizado, pressione F5 se você quiser fazer isso.

Name	Status	Reports		Severity	Trend	Actions
		Total	Last			
Verificação do Windows Server 2008	New					

Figura 14 – Iniciar uma nova tarefa para verificação do sistema de destino
 Fonte: Elaborado pelo autor (2020)

7) Quando o processo de verificação terminar, você perceberá que a barra do campo Status estará em 100%. Clique no nome da tarefa, nesse caso chamada de verificação do Windows Server 2008. Posteriormente, você poderá visualizar um

breve relatório, como o que é apresentado na Figura “Relatório de tarefa de verificação do sistema de destino”. Note que as opções definidas anteriormente, como o nome do sistema de destino, novamente são apresentadas, além das outras configurações. No entanto, o mais importante, nesse momento, é notar a quantidade apresentada no campo *Results* (resultados), no total são 46 vulnerabilidades encontradas no sistema.



Figura 15 – Relatório de tarefa de verificação do sistema de destino

Fonte: Elaborado pelo autor (2020)

8) Se você deseja visualizar com mais detalhes quais são as vulnerabilidades encontradas no sistema de destino, clique na opção *Results*. Para uma visualização em ordem decrescente, você deve clicar no título da coluna *Severity*, até que as vulnerabilidades com maior severidade sejam as primeiras.

Note também que existem muitos resultados relacionados aos registros de Logs, que podem ser tratados posteriormente, mas fique atento, pois as vulnerabilidades com maior nível de severidade são aquelas que devem ser tratadas imediatamente, ainda mais quando a classificação é 10.

9) A coluna *Vulnerability*, apresentada na Figura “Relatório de vulnerabilidades do sistema alvo”, lista todas as vulnerabilidades existentes no sistema alvo, observe

que quatro delas são classificadas com nível de severidade alta (High), como a tão conhecida Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4012289). Você a conhece em detalhes ou leu algo a respeito? Outras vulnerabilidades, como a Microsoft IIS Default Welcome Page Information Disclosure Vulnerability são classificadas com nível de severidade Média (Medium). Mesmo sem conhecer detalhes sobre os serviços no sistema alvo, podemos pressupor que existe um serviço web disponível nele, você concorda?

Vulnerability	Severity	QoD	Host	Location	Created
Microsoft Windows SMB2 Negotiation Protocol Remote Code Execution Vulnerability	10.0 (High)	98%	192.168.1.35	445/tcp	Thu Jan 9 03:28:45 2020
Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (High)	98%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft Windows SMB/NETBIOS NULL Session Authentication Bypass Vulnerability	7.5 (High)	99%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft IIS Default Welcome Page Information Disclosure Vulnerability	5.0 (Medium)	70%	192.168.1.35	80/tcp	Thu Jan 9 03:27:42 2020
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80%	192.168.1.35	135/tcp	Thu Jan 9 03:27:52 2020
SSL/TLS: Report Weak Cipher Suites	4.3 (Medium)	98%	192.168.1.35	3389/tcp	Thu Jan 9 03:27:01 2020
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	4.0 (Medium)	80%	192.168.1.35	3389/tcp	Thu Jan 9 03:27:44 2020
TCP timestamps	2.6 (Low)	80%	192.168.1.35	general/tcp	Thu Jan 9 03:27:58 2020
Services	0.0 (Log)	80%	192.168.1.35	80/tcp	Thu Jan 9 03:24:20 2020

Figura 16 – Relatório de vulnerabilidades do sistema alvo
Fonte: Elaborado pelo autor (2020)

Para conhecer mais detalhes sobre uma vulnerabilidade em especial, você pode selecioná-la clicando em seu nome na coluna *Vulnerability*. Por exemplo, detalhes da vulnerabilidade Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4012289).

10) Note que mais informações, com um pouco mais de detalhes, são apresentadas na Figura “Relatório de vulnerabilidades em detalhes”, você pode descobrir, logo de início na seção *Summary*, que esse *host* (sistema) precisa de uma atualização considerada crítica pela Microsoft. Além disso, o impacto causado se essa vulnerabilidade for explorada é grande. A solução proposta para mitigar essa vulnerabilidade, que nessa situação é algo bem simples, é atualizar o sistema. Lembra dos patches de segurança que foram comentados anteriormente e quais sistemas operacionais podem ser afetados.



Result: Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)

Vulnerability	Severity	QoD	Host	Location	Actions
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%	192.168.1.35	445/tcp	

Summary
This host is missing a critical security update according to Microsoft Bulletin MS17-010.

Vulnerability Detection Result
Vulnerability was detected according to the Vulnerability Detection Method.

Impact
Successful exploitation will allow remote attackers to gain the ability to execute code on the target server, also could lead to information disclosure from the server.

Solution
Solution type:  VendorFix
The vendor has released updates. Please see the references for more information.

Affected Software/OS
Microsoft Windows 10 x32/x64 Edition Microsoft Windows Server 2012 Edition Microsoft Windows Server 2016 Microsoft Windows 8.1 x32/x64 Edition Microsoft Windows Server 2012 R2 Edition Microsoft Windows 7 x32/x64 Edition Service Pack 1 Microsoft Windows Vista x32/x64 Edition Service Pack 2 Microsoft Windows Server 2008 R2 x64 Edition Service Pack 1 Microsoft Windows Server 2008 x32/x64 Edition Service Pack 2

Vulnerability Insight
Multiple flaws exist due to the way that the Microsoft Server Message Block 1.0 (SMBv1) server handles certain requests.

Vulnerability Detection Method
Send the crafted SMB transaction request with fid = 0 and check the response to confirm the vulnerability.
Details: [Microsoft Windows SMB Server Multiple Vulnerabilities-Remote \(4013389\)](#) (OID: 1.3.6.1.4.1.25623.1.0.810676)
Version used: 2019-05-03T10:54:50+0000

References
CVE: [CVE-2017-0143](#), [CVE-2017-0144](#), [CVE-2017-0145](#), [CVE-2017-0146](#), [CVE-2017-0147](#), [CVE-2017-0148](#)
BID: [96703](#), [96704](#), [96705](#), [96707](#), [96709](#), [96706](#)
CERT: [CB-K17/0435](#), [DFN-CERT-2017-0448](#)
Other: <https://support.microsoft.com/en-in/kb/4013078>
<https://technet.microsoft.com/library/security/MS17-010>
<https://github.com/rapid7/metasploit-framework/pull/8167/files>

Figura 17 – Relatório da vulnerabilidade em detalhes
Fonte: Elaborado pelo autor (2020)

Sobre o resultado apresentado na Figura “Relatório de tarefa de verificação do sistema de destino”, você ainda pode notar que a seção *References* informa sobre como buscar mais informações sobre a vulnerabilidade. Você lembra da identificação CVE, disponível no site *Common Vulnerabilities and Exposures*? Então, em posse desse identificador, você pode buscar mais informações no site CVE e planejar de forma adequada a aplicação para realizar essa correção.

8 INSTALANDO E CONFIGURANDO O NESSUS ESSENTIALS NO KALI LINUX

Entre as diversas soluções existentes para avaliação de vulnerabilidades, como apresentado anteriormente, optamos por duas: o OpenVAS, que há pouco você pôde conhecer e utilizá-lo e agora o **Nessus Essentials**.

O **Nessus Essentials** apresenta uma ótima solução de avaliação de vulnerabilidades. E essa versão, utilizada aqui, oferece de forma gratuita uma solução de avaliação de vulnerabilidades, na qual é possível verificar até 16 IPs, isto é, diferentes sistemas de destinos.

Segundo a Tenable, a equipe responsável pelas pesquisas trabalha em colaboração com a comunidade de segurança para descobrir novas vulnerabilidades e fornecer informações sobre as vulnerabilidades publicadas para ajudar as organizações a detectá-las rapidamente em seu ambiente (TENABLE, s.d.).

Se suas máquinas virtuais estão prontas, você pode executar a versão do Kali Linux. Vale lembrar que as configurações das máquinas virtuais serão as mesmas, visto que o cenário será mantido e o que acrescenta agora é que você iniciará a instalação do *Nessus Essentials*.

1) A partir da máquina virtual Kali Linux, você deve acessar o site <https://pt-br.tenable.com/try> para obter o arquivo de instalação da versão de avaliação do Nessus. No site da Tenable, a página “Introdução às soluções de Cyber Exposure da Tenable” permite selecionar diversas versões, mas como comentado anteriormente, a proposta é fazer *download* da versão *Nessus Essentials*.

2) Como mostrado na Figura “Página de registro para uso do Nessus Essentials”, clique no botão Teste gratuito e em seguida, faça o cadastro. Quando você terminar, receberá orientações via e-mail, inclusive um código de ativação.

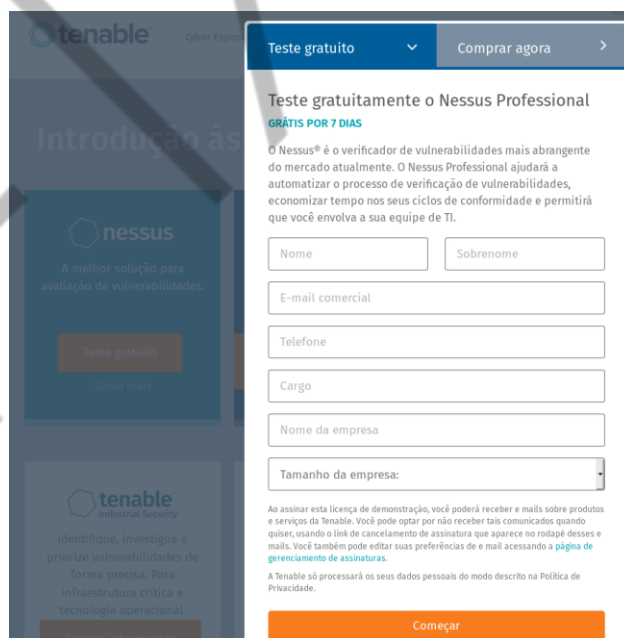
A imagem mostra a interface de usuário da página de registro do Nessus Essentials. No topo, há uma barra de navegação com "Teste gratuito" selecionado e "Comprar agora". O título principal é "Teste gratuitamente o Nessus Professional GRÁTIS POR 7 DIAS". Abaixo, há um texto descritivo sobre o produto. O formulário de registro inclui campos para: Nome, Sobrenome, E-mail comercial, Telefone, Cargo, Nome da empresa e Tamanho da empresa (menu suspenso). Na base do formulário, há um texto de consentimento e um botão laranja "Começar".

Figura 18 – Página de registro para uso do Nessus Essentials
Fonte: Elaborado pelo autor (2020)

3) Quando o *download* do arquivo de instalação terminar, utilize o terminal do Linux para acessar o local no qual o arquivo está. Em seguida, você pode manipular o pacote do Nessus com o comando:


```
dpkg -i Nessus-8.6.0-debian6_amd64.deb
```

Comando de prompt 3 – Instalação do Nessus Essentials utilizando dpkg
Fonte: Elaborado pelo autor (2020)

4) A Figura “Instalação do *Nessus Essentials*” mostra, a partir do terminal, o acesso ao diretório Downloads, local onde foi feito o *download* do arquivo, uma listagem para verificar se o arquivo está presente e o início do processo de instalação.

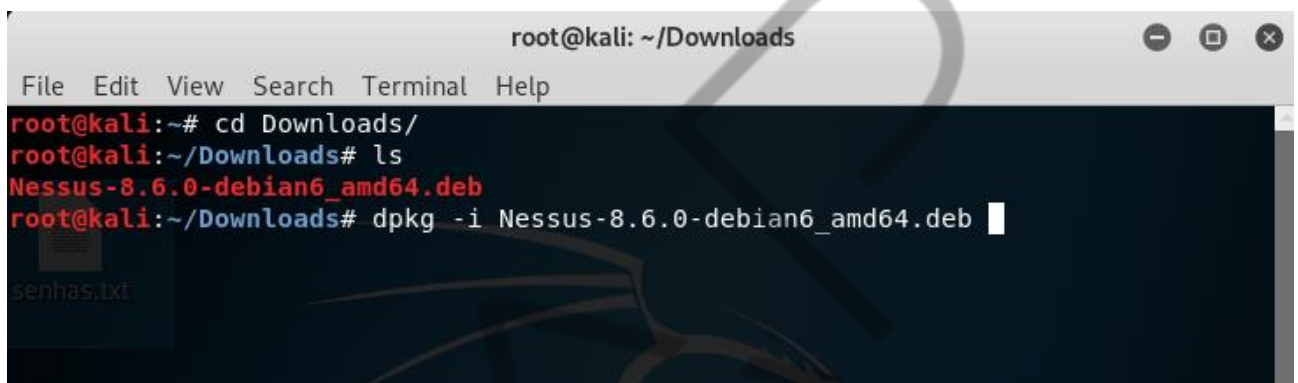


Figura 19 – Instalação do *Nessus Essentials*
Fonte: Elaborado pelo autor (2020)

5) Quando o processo terminar e o *prompt* de comando estiver disponível, você deve iniciar o processo Nessus digitando a seguinte linha de comando:

```
/etc/init.d/nessusd start
```

Comando de prompt 4 – Subindo o daemon do Nessus Essentials
Fonte: Elaborado pelo autor (2020)

6) Em seguida, utilize o navegador web e digite o seguinte endereço:

```
http://kali:8834
```

Comando de prompt 5 – Endereço de navegador para acesso do painel do Nessus Essentials
Fonte: Elaborado pelo autor (2020)

Observe que a palavra kali é o nome do host e 8834 é a porta em que o serviço do Nessus está disponível. Note que, se necessário, você deverá adicionar uma exceção para esse endereço.

A partir desse momento, o processo de inicialização estará em execução e você deve seguir os procedimentos em cada uma das telas.

1. Na tela **Welcome to Nessus**, selecione a opção para: **Nessus Essentials**.
2. Se você não conseguiu fazer o cadastro, então na tela **Get a activation code** deve fazer nesse momento. Se o cadastro feito anteriormente está correto e você recebeu um e-mail de confirmação, então clique no botão **Skip**.
3. Na tela **Register Nessus**, utilize o código de ativação enviado para o seu e-mail.
4. Na tela **Create a user account**, defina seu *username* e *password* para acessar e gerenciar o Nessus. Anote seu *login* e senha para logar na aplicação quando necessário.
5. Após criar seu login, o Nessus deverá fazer o *download* dos *plugins* e você deverá aguardar enquanto o Nessus prepara todos os arquivos para que posteriormente a aplicação esteja disponível. Esse processo é demorado e pode levar em média meia hora, mas, é claro, dependendo da sua velocidade de conexão com a Internet.



Figura 20 – Instalação do *plug-ins* do *Nessus Essentials*
Fonte: Elaborado pelo autor (2020)

6. Quando o processo de instalação e configuração do Nessus estiver concluído, será apresentada a você a tela para fazer *login*, utilize as credenciais

cadastradas anteriormente. Assim que você acessar o **Nessus**, o Painel de controle apresentado será semelhante ao da Figura “Painel *My Scans* do *Nessus Essentials*”, na qual é possível visualizar opções para criar um novo procedimento de verificação de vulnerabilidades.

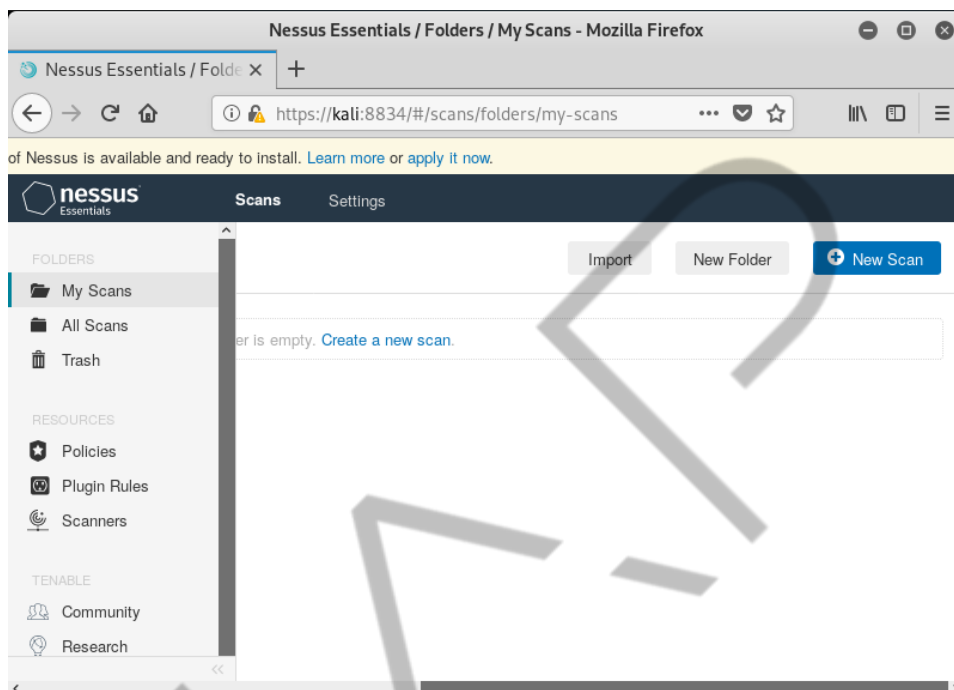


Figura 21 – Painel *My Scans* do *Nessus Essentials*
Fonte: Elaborado pelo autor (2020)

7. O botão *New Scan*, disponível na guia *My Scans*, permite que você acesse um painel, como o da Figura “Painel *Scan Template* do *Nessus Essentials*”, com diversos modelos de verificação, tais como *Basic Network Scan*, *Host Discover*, *Malware Scan*, *Web Application Tests*, entre outras opções disponíveis, de forma gratuita.

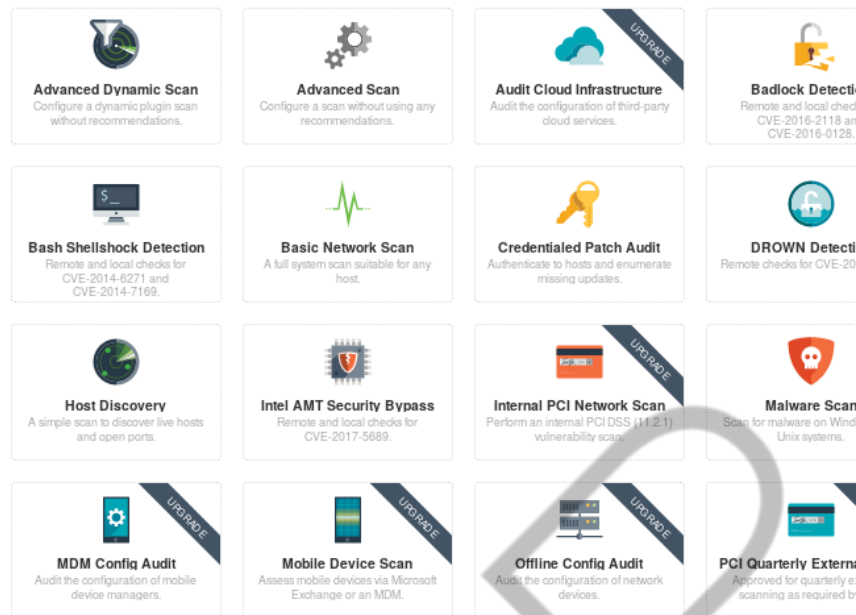


Figura 22 – Painel Scan Template do Nessus Essentials

Fonte: Elaborado pelo autor (2020)

8. Seguindo um procedimento bem parecido com a utilização do OpenVAS, você deve selecionar a opção *Basic Network Scan* e preencher os campos *Name*, *Description* e *Targets*, como mostrado na Figura “Painel Scan Template do Nessus Essentials”. Vale lembrar que o sistema destino será o mesmo utilizado no OpenVAS e que estamos selecionando e configurando esse processo com a menor quantidade de opções.

 A screenshot of the 'Basic Network Scan' configuration panel. It shows fields for Name, Description, Folder, and Targets.

- Name**: Windows Server 2008
- Description**: Verificação de vulnerabilidades no sistema Windows Server 2008
- Folder**: My Scans (dropdown menu)
- Targets**: 192.168.1.35

 At the bottom, there is a section for 'Upload Targets' with a blue 'Add File' button.

Figura 23 – Painel Basic Network Scan do Nessus Essentials

Fonte: Elaborado pelo autor (2020)

Se você tiver um arquivo com uma lista de vários sistemas, poderá fazer upload desse arquivo clicando na opção **Add File**. Além disso, pode digitar manualmente vários endereços IPS no campo *Targets*, porém não esqueça de utilizar a vírgula para separar cada um deles.

9. Nesse instante em que as opções estão preenchidas, você deverá clicar no botão *Save*. Prontamente você retornará para a tela inicial, em outras palavras, em *My Scans*, a diferença é que existe uma tarefa chamada Windows Server 2008, esperando ser iniciada.

10. Que tal executá-la? Clique no botão *Launch*, formato de seta (*play*), no lado extremo direito do nome da tarefa. Aguarde até finalizar a verificação de vulnerabilidades no sistema Windows Server 2008.

Porém, quando estiver finalizada, você poderá visualizar as vulnerabilidades encontradas, como as apresentadas na Figura “Resultado da verificação de vulnerabilidades no sistema Windows Server 2008”. Atente-se que nessa verificação foram encontradas 4 vulnerabilidades consideradas críticas, 1 alta, 8 médias, 1 baixa e o restante como Info, ou seja, registros.

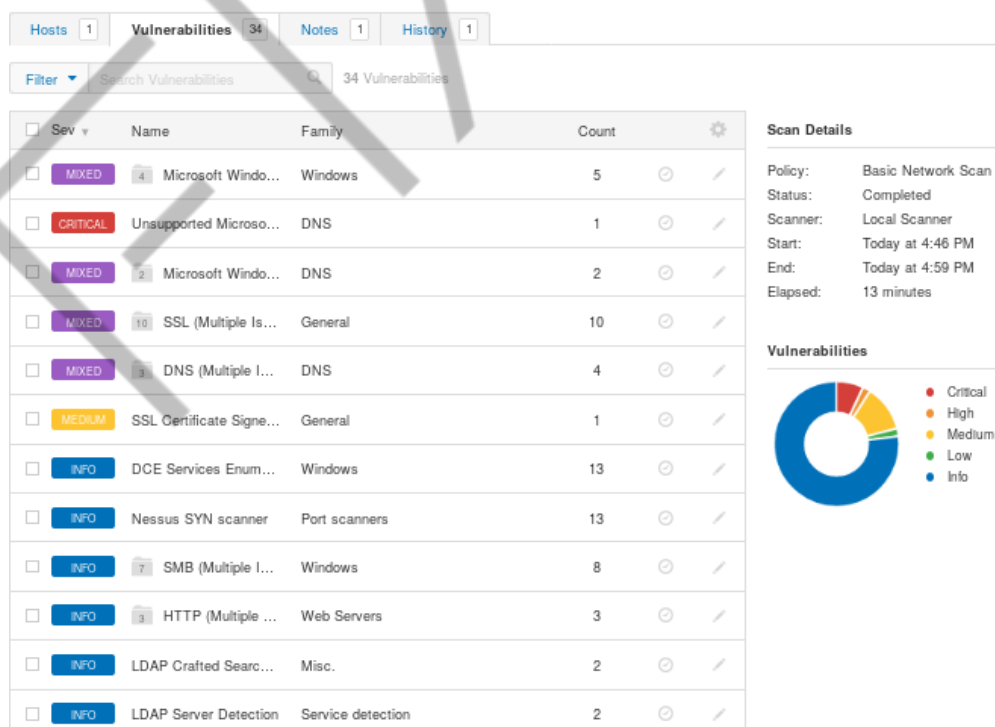


Figura 24 – Resultado da verificação de vulnerabilidades no sistema Windows Server 2008
Fonte: Elaborado pelo autor (2020)

Você pode notar até aqui que o processo de verificação de vulnerabilidades conta com ferramentas para automatizar esse processo e que é necessário executá-lo continuamente, para que possíveis fraquezas sejam descobertas e exploradas em acessos não autorizados. No entanto, fique ciente de que possíveis obstáculos podem aparecer, um deles é ter que conquistar a aceitação pela equipe de TI, porque geralmente exigem solicitações adicionais para que você possa executar essas ferramentas, visto que elas afetam negativamente a infraestrutura de TI. Imagine só ter que executar uma verificação de vulnerabilidades em um servidor em produção, desta forma, um bom planejamento é essencial para uma gestão de vulnerabilidades efetiva.

Mas não acabou ainda, dado que ainda existem etapas a serem conquistadas pós verificação.

9 ETAPA 3: PRIORIZANDO OS RESULTADOS DA VERIFICAÇÃO

Durante os últimos anos, as vulnerabilidades são exploradas pelos invasores por meio das fraquezas existentes nos aplicativos e sistemas operacionais. Situações como essas deixam claro o quão crucial é corrigir vulnerabilidades em seus sistemas.

Corrigir todas as vulnerabilidades de uma só vez é praticamente impossível. Imagine em grandes organizações, a quantidade de dados de vulnerabilidade pode ser imensa se você não os categorizar, segmentar e priorizar adequadamente de maneira significativa as correções.

Um fluxo de trabalho funcional na gestão de vulnerabilidades e com utilização de ferramentas permite classificar automaticamente as vulnerabilidades para determinar os problemas mais críticos que podem impactar os sistemas mais críticos. As ferramentas de verificação de vulnerabilidades devem indicar o patch mais eficiente para você aplicar a uma vulnerabilidade, levando em conta esses dados automaticamente em consideração ao listar as vulnerabilidades mais importantes a serem corrigidas. Esse recurso pode melhorar sua eficácia na aplicação de patches.

Para otimizar seu fluxo de trabalho em relação às correções das vulnerabilidades que possuem explorações associadas e conhecidas, você pode procurar filtrar as vulnerabilidades detectadas em categorias. Essas categorias podem ser ordenadas em relação à redução de risco mais alto, à redução de risco médio e

mais baixo, como visualizado na Figura “Resultados priorizados de verificações de vulnerabilidades”.

Sev	Name	Family	Count	
MIXED	Microsoft Windo...	Windows	5	
CRITICAL	Unsupported Microso...	DNS	1	
MIXED	Microsoft Windo...	DNS	2	
MIXED	SSL (Multiple Is...	General	10	
MIXED	DNS (Multiple I...	DNS	4	

Vulnerability	Severity	QoD	Host	Location	Created
Microsoft Windows SMB2 Negotiation Protocol Remote Code Execution Vulnerability	10.0 (High)	98%	192.168.1.35	445/tcp	Thu Jan 9 03:28:45 2020
Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (High)	98%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft Windows SMB/NETBIOS NULL Session Authentication Bypass Vulnerability	7.5 (High)	99%	192.168.1.35	445/tcp	Thu Jan 9 03:28:50 2020
Microsoft IIS Default Welcome Page Information Disclosure Vulnerability	5.0 (Medium)	70%	192.168.1.35	80/tcp	Thu Jan 9 03:27:42 2020
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80%	192.168.1.35	135/tcp	Thu Jan 9 03:27:52 2020
SSL/TLS: Report Weak Cipher Suites	4.3 (Medium)	98%	192.168.1.35	3389/tcp	Thu Jan 9 03:27:01 2020
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	4.0 (Medium)	80%	192.168.1.35	3389/tcp	Thu Jan 9 03:27:44 2020
TCP timestamps	2.6 (Low)	80%	192.168.1.35	general/tcp	Thu Jan 9 03:27:58 2020
Services	0.0 (Log)	80%	192.168.1.35	80/tcp	Thu Jan 9 03:24:20 2020

Figura 25 – Resultados priorizados de verificações de vulnerabilidades
Fonte: Elaborado pelo autor (2020)

10 ETAPA 4: CORRIGINDO VULNERABILIDADES

A correção de vulnerabilidades deve ser tratada com muita disciplina no processo de gestão de vulnerabilidades, pois deve ser realizada para que os riscos sejam mitigados e diminuam as possíveis implicações para uma organização.

Os processos manuais tradicionais para encontrar falhas, sugerir correções e outras ações de correção são muito lentos, propensos a erros e em muitas vezes caros para serem usados com eficiência. Além disso, o alto custo de aplicação de patches, juntamente com o alto volume de falhas detectadas em aplicativos de software, às vezes incentiva as organizações a adiar a correção. Isso pode levar uma organização a atrasar as atualizações, mesmo para patches críticos ou atualizações grandes e altamente testadas, como *service packs*.

Imagine as organizações que não se prepararam para o fim da vida de um sistema operacional, falharam em substituir o sistema operacional antigo e agora enfrentam imensos problemas. Uma alternativa, em situações como essa, pode ser pagar o valor máximo de cada patch necessário e continuar usando um sistema

operacional que pode ser facilmente invadido por qualquer invasor moderadamente qualificado. Mas essa não é a melhor das opções. Concorde?

A correção de vulnerabilidades é essencial e, felizmente, bons fornecedores de software corrigem falhas regularmente em seus produtos e realizam extensos testes nas novas versões. O sistema operacional, o navegador da Internet e as atualizações padrão de aplicativos devem ser transparentes para os seus negócios e não causar interrupção no seu fluxo de trabalho.

Se você tiver configurações especiais que não são cobertas pelos testes do fornecedor de software, faz sentido você executar seu próprio pré-teste nos patches antes de aplicá-los aos sistemas ativos. Portanto, ficam aqui algumas dicas para pré-teste:

- Garanta que os testes ocorram no ambiente exclusivo da sua organização. A maioria dos problemas com *patches* é devido a aplicativos de terceiros ou modificações nas configurações padrão.
- Verifique a integridade dos patches comparando somas de verificação (*checksums*) com as informações fornecidas pelos fornecedores de software.
- Verifique se o *patch* corrige a vulnerabilidade sem afetar os aplicativos e operações do processo de negócios.

E para o gerenciamento de *patches*, você pode seguir essas outras dicas:

- Corrija as vulnerabilidades o mais rápido possível e minimize os riscos aplicando os patches na prioridade que descrevemos na Etapa 3, ou seja, observando o nível de severidade de cada uma delas.
- Adote soluções automatizadas de gerenciamento de patches e distribuição de *software*.

11 INFORMES DE VULNERABILIDADE PRECISOS

11.1 Etapa 5: Mantendo-se informado

A solução para gestão de vulnerabilidades que você adota deve mantê-lo totalmente informado sobre o estado de segurança dos sistemas e da rede da sua empresa.

Seu informante confiável serão os relatórios e painéis de controle internos que permitem personalizar o tipo e a apresentação das informações de vulnerabilidade exatamente como você precisa.

Exemplos de relatórios típicos, como os mostrados nas Figuras “Relatório de tarefa de verificação do sistema de destino”, “Relatório de vulnerabilidades do sistema alvo” e “Relatório da vulnerabilidade em detalhes”, respectivamente, incluem:

- Um painel, que fornece um resumo rápido das vulnerabilidades e do status da correção;
- Resumo da vulnerabilidade, que lista todas as vulnerabilidades por prioridade;
- Análise de ameaças, que detalha ameaças específicas a cada dispositivo na rede e permite a análise detalhada de problemas específicos.

12 UMA SOLUÇÃO PARA VERIFICAÇÃO DE VULNERABILIDADES

Na hora de escolher uma solução ou ferramenta para verificação de vulnerabilidades, você deve procurar por algo que atenda às necessidades da organização. De forma geral, uma boa solução deve conter recursos para:

- Mapear sua rede e todos os seus dispositivos;
- Verificar com precisão e eficiência o maior número potencial de vulnerabilidade;
- Relatar de forma clara e abrangente os resultados da verificação;
- Testar e confirmar se as vulnerabilidades estão corrigidas;

- Produzir automaticamente relatórios precisos, abrangentes e detalhados para verificar a conformidade com políticas internas e regulamentos de segurança legalmente exigidos;
- Ajudar a repetir automaticamente essas etapas como parte de um processo contínuo para garantir a segurança da rede.

Você foi apresentado a duas ferramentas muito interessantes, mas é claro que existem inúmeras outras disponíveis para atender às necessidades da organização e ajudá-lo nessa tarefa contínua.

13 ETAPA 6: REPETIR CONTINUAMENTE

Para que você não pense que as tarefas estão concluídas após uma primeira verificação, esteja ciente que a gestão de vulnerabilidades contínua significa que as cinco etapas anteriores são realmente um processo contínuo e devem ser repetidas quantas vezes forem necessárias.

A gestão de vulnerabilidades é necessária, porque, no passado, as redes de computadores eram estáticas e raramente mudavam. Atualmente, as redes corporativas e governamentais são distribuídas, complexas e altamente dinâmicas, com equipes operacionais independentes gerenciando e alterando configurações de *firewalls*, roteadores, *switchs*, balanceadores de carga, hosts, aplicativos e outros sistemas. Além disso, as redes agora incluem não apenas dispositivos de propriedade da empresa, mas também dispositivos pertencentes a indivíduos (colaboradores) que nem sempre seguem as mesmas práticas rígidas de aplicação de patches e segurança.

Isso representa uma oportunidade significativa para os cibercriminosos explorarem vulnerabilidades recém-introduzidas e se infiltrarem nas redes entre as verificações. As novas vulnerabilidades em *software* para dispositivos e aplicativos são descobertas todos os dias, outra fonte de ameaças que podem explorar configurações operacionais que mudam a cada minuto.

Os invasores estão aproveitando os serviços em computação em nuvem para varrer e atacar continuamente vulnerabilidades em suas redes e sistemas, geralmente em velocidades que superam sua capacidade de reagir. Nesta nova era de crimes cibernéticos, você realmente deve estar à frente para identificar e corrigir as

vulnerabilidades mais rapidamente. Com isso, ao executar continuamente as etapas da gestão de vulnerabilidades, sua empresa pode acompanhar as novas vulnerabilidades e tomar medidas imediatas para proteger a segurança da sua rede. As verificações contínuas também são uma maneira importante de garantir o sucesso dos esforços de correção da sua equipe de segurança.

EMAN

REFERÊNCIAS

HABER M. J., HIBBERT, B. **Vulnerability Management Operations**. In: HABER M. J., HIBBERT, B. Asset Attack Vectors. Apress, Berkeley, CA. 2018.

KALI. **Kali Linux Downloads**. Disponível em: <<https://www.kali.org/downloads/>>. Acesso em: 8 abr. 2021.

NATIONAL VULNERABILITY DATABASE. **Vulnerability Metrics**. Disponível em: <<https://nvd.nist.gov/vuln-metrics/cvss>>. Acesso em: 6 jan. 2020.

OPENVANS. [s.d.]. Disponível em <<http://www.openvas.org/about.html>>. Acesso em: 4 jan. 2020.

SCARFONE, K. *et al.* **Technical Guide to Information Security Testing and Assessment**. [s.l]: NIST, 2018. Disponível em: <<http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf>>. Acesso em: 7 jan. 2020.

TENABLE. **A Família Nessus**. [s.d.]. Disponível em: < <https://pt-br.tenable.com/products/nessus> >. Acesso em: 4 jan. 2020.